

Module 28: Digital Forensics & Incident Analysis

CAPSTONE CERTIFICATION MODULE

Curriculum Reference: NetAcad Module 28

Cisco Certified CyberOps Associate (CBROPS 200-201)

Standards: NIST SP 800-61 Rev 2 | RFC 3227

1. DIGITAL FORENSICS PRINCIPLES & EVIDENCE HANDLING

CORE DEFINITION

Forensic Science in CyberOps

**Digital Forensics** is the scientific identification, collection, examination, and analysis of digital evidence while preserving data integrity and maintaining an unbroken chain of custody for legal and operational purposes.

- The Golden Rule:** Never perform forensic examination on original physical evidence. Always clone a bit-stream duplicate and work solely on the forensic image.
- Hardware Write-Blockers:** Physical bridges that permit read commands while suppressing write signals to prevent forensic contamination.

VERIFICATION

Cryptographic Hashing

Evidence integrity is mathematically proven using cryptographic hashes (**SHA-256**). If the target forensic image hash matches the suspect physical drive, evidence is validated.

```
# PowerShell Evidence Verification Syntax: Get-FileHash -Path suspect_drive.dd -Algorithm SHA256 Hash: A5B78F49E3C29D120B44F8E... [MATCH = VALID]
```

The *Avalanche Effect* guarantees that altering even a single bit completely changes the hash, proving tampering instantly.

2. ORDER OF VOLATILITY (RFC 3227) & EVIDENCE HIERARCHY

When responding to an active security incident, evidence must be collected in order from **most volatile** (disappears immediately upon power loss) to **least volatile**:

| Priority       | Evidence Source                              | Volatility Lifespan               | Forensic Value / Artifacts                                                                                       |
|----------------|----------------------------------------------|-----------------------------------|------------------------------------------------------------------------------------------------------------------|
| 1<br>(Highest) | CPU Registers, On-chip Cache                 | Nanoseconds to Microseconds       | Immediate processor state, decrypted CPU instruction buffers.                                                    |
| 2              | Routing Table, ARP Cache, Process Table, RAM | Seconds to Hours (Lost at reboot) | <b>Physical RAM:</b> Injected fileless malware, active TCP/UDP sockets, decrypted passwords, cryptographic keys. |
| 3              | Temporary File Systems, Swap Space           | Hours to Days                     | Virtual memory paging files, temporary execution dumps.                                                          |
| 4              | Local Disk Storage (NVMe, SSD, HDD)          | Months to Years                   | Master File Table (\$MFT\$), deleted file clusters, file slack, registry hives.                                  |
| 5              | Remote Logging & Monitoring Data             | Weeks to Months (Retention-based) | Syslog, SIEM correlation alerts, NetFlow / IPFIX traffic flow records.                                           |
| 6<br>(Lowest)  | Archival Backups, Tapes, Optical Media       | Years to Decades                  | Cold storage backups, disaster recovery tape archives.                                                           |

**CRITICAL SOC OPERATIONAL RULE:** *Never immediately pull the power plug or reboot a live compromised system!* Rebooting destroys CPU registers, cache, ARP tables, and RAM (Priority 1 & 2), destroying the only proof of fileless

malware execution and C2 network sockets. Always perform a **live volatile memory capture** (WinPmem, FTK Imager CLI, LiME) before power down.

# NIST SP 800-61 Rev 2 Incident Handling Lifecycle

NIST SPECIAL PUBLICATION

Computer Security Incident Handling Guide

## Standardized Incident Response Framework & Operating Procedure

Version: SP 800-61 Revision 2

### 3. THE 4 PHASES OF THE INCIDENT RESPONSE LIFECYCLE

#### PHASE 1 Preparation

Establishing defense capabilities *before* an attack occurs:

- Creating pre-approved **Incident Response Playbooks** for ransomware, phishing, and DDoS.
- Preparing forensic hardware jump kits, sterile storage media, and write-blockers.
- Establishing **out-of-band communication channels** (signal groups, satellite phones) in case corporate email is compromised.
- Conducting regular Tabletop Exercises (TTX) and war games.

#### PHASE 2 Detection and Analysis

Identifying and prioritizing active security threats:

- **Precursors:** Signs of future attacks (e.g., port scans, dark web reconnaissance chatter).
- **Indicators of Compromise (IoCs):** Signs that an attack is occurring or has succeeded (e.g., AV alerts, C2 beacons, unauthorized admin accounts).
- Scoping incident severity based on **functional impact**, **data sensitivity**, and **recoverability**.

#### PHASE 3 Containment, Eradication & Recovery

Neutralizing the adversary and restoring operations safely:

- **Short-Term Containment:** Isolating the infected host via network quarantine or VLAN change to stop lateral movement while preserving volatile memory.
- **Long-Term Containment:** Applying temporary firewall filters, rotating domain admin credentials, and rerouting traffic through WAF proxies.
- **Eradication:** Purging malware binaries, persistence registry keys, and remediating the root-cause vulnerability.
- **Recovery:** Restoring from verified clean offline backups with **enhanced monitoring** for 30+ days.

#### PHASE 4 Post-Incident Activity

Driving continuous defense improvement:

- Convening a **Blameless Lessons Learned Meeting** within **14 days** of ticket closure while recollection is clear.
- Answering: *What happened? Did playbooks work? What precursors were missed? How do we prevent recurrence?*
- Generating formal executive incident post-mortems and archiving legal evidence according to retention policies (3–7 years).

### 4. EVIDENCE ADMISSIBILITY & LEGAL CLASSIFICATIONS

| Evidence Class           | Legal Standard / Meaning                                                 | SOC / CyberOps Real Example                                                  |
|--------------------------|--------------------------------------------------------------------------|------------------------------------------------------------------------------|
| Best Evidence (Original) | The original physical medium or an exact, verified bit-stream duplicate. | The physical suspect NVMe drive or its bit-by-bit verified '.E01' raw image. |

| Evidence Class                 | Legal Standard / Meaning                                               | SOC / CyberOps Real Example                                                    |
|--------------------------------|------------------------------------------------------------------------|--------------------------------------------------------------------------------|
| <b>Direct Evidence</b>         | Directly proves a fact without requiring any presumption or inference. | Security camera footage showing a rogue contractor typing on the console.      |
| <b>Circumstantial Evidence</b> | Proves a fact through correlation and reasonable inference.            | A server login log from an overseas IP coinciding with badge gate entry.       |
| <b>Corroborating Evidence</b>  | Supplementary evidence that reinforces or validates primary evidence.  | A Snort IDS alert backed up by a firewall drop log and process creation event. |

## 5. GLOBAL COORDINATION & THE VERIS FRAMEWORK

- **CSIRT Team Models:** Centralized (single global SOC), Distributed (regional response teams), Coordinating (advisory role, e.g., US-CERT / CISA).
- **Threat Communities:** FIRST (Forum of Incident Response and Security Teams), Sector ISACs (Financial, Healthcare).
- **VERIS (Vocabulary for Event Recording and Incident Sharing):** The **4A Model** used in the Verizon DBIR: **Actors** (Who?), **Actions** (What did they do?), **Assets** (What was hit?), and **Attributes** (Which CIA pillar was violated?).